

Executive Summary: ISO 27001:2022 Baseline Gap Analysis
Objective: To evaluate the organization's current information security posture against the ISO/IEC 27001:2022 framework, identify critical vulnerabilities, and provide a strategic roadmap for certification readiness.

Scope: The assessment covers core operational domains including Access Control, Threat & Vulnerability Management, and Incident Response within a hybrid cloud environment.

High-Level Findings:
While foundational security measures exist, the organization currently operates at a Moderate-to-High risk level due to decentralized control enforcement. Key systemic gaps include:

Access Control (Domain 5): Inconsistent enforcement of privileged access and lack of formalized identity governance.

Incident Management (Domain 16): Absence of centralized telemetry and undocumented response playbooks for cloud-based threats.

Vulnerability Management (Domain 8): Irregular scanning cadences and lack of automated baseline enforcement on critical servers.

Strategic Recommendation:
Implement a phased remediation strategy, prioritizing the standardization of identity management and the deployment of a centralized security information and event management (SIEM) architecture to achieve immediate risk reduction.

Control ID	Control Objective	Current State	Gap Identified	Risk Level	Remediation Action	Implementation Status
A.5.15	Rules to control logical access to information and assets shall be established and implemented based on business requirements.	Access is granted ad-hoc via IT helpdesk tickets. No formalized Role-Based Access Control (RBAC) matrix exists for cloud environments.	Lack of documented access control policy and formalized RBAC model mapping users to minimum required permissions.	High	Define and publish an Access Control Policy. Implement RBAC architecture using Microsoft Entra ID security groups.	Not Started
A.8.5	Secure authentication technologies and procedures shall be implemented based on information access restrictions.	Standard passwords are used for most systems. Multi-Factor Authentication (MFA) is only enforced for IT administrators.	Weakly enforced MFA for non-admin user resources accessing cloud-hosted financial applications and email.	High	Deploy Microsoft Entra ID Conditional Access policies to enforce MFA for all users accessing Microsoft 365 and external SaaS apps.	In Progress
A.8.2	The allocation and use of privileged access rights shall be restricted and managed.	Global Admin accounts are used for daily operational tasks. Privileged accounts are standing and not actively monitored.	Standing administrative privileges exist without oversight, time limits, or justification logging.	High	Implement Microsoft Entra Privileged Identity Management (PIM) for Just-In-Time (JIT) access and require approval workflows for elevated roles.	Not Started
A.5.18	Access rights to information and other associated assets shall be provisioned, reviewed, modified and removed.	User access is not systematically reviewed. Deprovisioning manualized employees relies on manual IT checklists.	Lack of automated deprovisioning and absence of regular quarterly access certification reviews.	Medium	Configure Entra ID Access Reviews for automated quarterly auditing of privileged groups. Automate offboarding script execution.	Not Started
A.16.1.1	Management responsibilities and procedures shall be established to ensure a quick, effective, and orderly response to information security incidents.	Incident response relies on informal, undocumented procedures. No formal playbooks exist for cloud-specific threats.	Lack of formalized, management-approved Incident Response Plan (IRP) and cloud-specific escalation playbooks.	High	Draft and formalize a comprehensive Incident Response Plan (IRP) with specific playbooks for AWS and Azure environments.	Not Started
A.16.1.2	Information security events shall be reported through appropriate management channels as quickly as possible.	Security telemetry is siloed across different cloud platforms. Alerts are reviewed manually without a centralized aggregation tool.	Absence of a centralized Security Information and Event Management (SIEM) solution to aggregate and analyze multi-cloud telemetry.	High	Deploy Microsoft Sentinel as the central SIEM. Integrate AWS CloudTrail and Azure Monitor telemetry using data connectors.	In Progress
A.16.1.4	Information security incidents shall be assessed and decisions on the appropriate response shall be made.	Incident triage is performed inconsistently without standardized severity matrices or automated threat intelligence correlation.	Lack of automated triage capabilities and standardized threat intelligence feeds to enrich incident data.	Medium	Configure custom KQL (Kusto Query Language) analytic rules in Microsoft Sentinel to automate threat detection and integrate threat intelligence feeds.	Not Started
A.16.1.5	Procedures for incident response and recovery shall be established and implemented.	Remediation efforts are entirely manual, leading to delayed response times during off-hours.	Absence of Security Orchestration, Automation, and Response (SOAR) capabilities for automated containment.	Medium	Develop Azure Logic Apps within Microsoft Sentinel to automate tier-1 containment actions, such as isolating compromised virtual machines.	Not Started
A.8.8	Information about technical vulnerabilities of information systems being used shall be obtained, exposure evaluated, and appropriate measures taken.	Vulnerability scanning is performed ad-hoc. No authenticated scans are run against internal Linux or Windows environments.	Lack of regular, automated vulnerability scanning and centralized vulnerability tracking.	High	Deploy Tenable Nessus to execute weekly authenticated scans across all Red Hat Enterprise Linux (RHEL) and Windows Server environments.	Not Started
A.8.9	Hardware, software, services, and networks shall be configured in accordance with established security requirements.	Server configurations are applied manually. No standardized hardening baselines are currently enforced.	Absence of documented security baselines (e.g., CIS Benchmarks) and automated compliance checking.	Medium	Define hardening standards using CIS Benchmarks. Utilize Tenable Nessus compliance scanning to audit baseline deviations.	Not Started
A.8.19	Procedures shall be implemented to manage the installation of software on operational systems.	Software updates are performed manually and reactively, resulting in delayed deployments for critical security updates.	No formalized patch management lifecycle or defined Service Level Agreements (SLAs) for zero-day vulnerability mitigation.	High	Establish a formal Patch Management Policy. Define a 48-hour SLA for testing and deploying critical zero-day patches.	In Progress